本文档为技术演示用的虚构示例（星澜科技为虚构企业），与任何真实企业无关，仅用于 Agent 项目知识库演示。

星澜科技 多租户与数据隔离规范

第 1 章 目的与背景

1.1 目的

星澜科技的客户数据平台由集团下属多家子公司共用。为避免不同子公司之间互相看到数据，明确租户模型与隔离要求，制定本规范。

1.2 租户模型

一个子公司对应一个租户，租户以 tenant_id 标识，贯穿账号、业务数据、知识库、日志与计费全链路。员工归属唯一租户，跨租户协作须通过数据共享流程。

第 2 章 隔离要求

2.1 查询强制隔离

所有数据查询必须携带 tenant_id 作为过滤条件，禁止无条件全表查询。缺少租户条件的查询在代码评审中一律驳回，上线后由数据库审计插件拦截。

2.2 存储层隔离

关系型数据库按 tenant_id 建行级隔离并启用行级安全策略；向量库按 tenant_id 过滤并在集合元数据中标记；对象存储按 tenant_id 目录前缀隔离；缓存键必须以 tenant_id 作为前缀。

2.3 跨租户访问

任何跨租户读取一律拒绝。确因业务需要（如集团报表）的，须经数据治理委员会批准，使用专用聚合账号并脱敏后输出，禁止通过业务接口直接读取。

第 3 章 知识库与检索隔离

3.1 知识库归属

知识库文章归属单一租户，检索时强制带租户过滤。集团通用制度可发布为共享知识库，由集团管理员单独维护，各租户只读。

3.2 检索与引用

检索结果仅返回本租户内容；引用来源须显示文档标题与章节，不得暴露其他租户的文档编号。发现串租户结果视为 P1 数据事故。

第 4 章 数据导出与共享

4.1 导出审批

导出范围	审批人	附加要求
单租户内部数据	租户管理员	记录导出人与用途
跨租户汇总数据	数据治理委员会	必须脱敏并留存审批单
涉及个人信息	法务与安全负责人	签署数据共享协议

4.2 共享与留存

跨租户共享须双方书面同意并留存 3 年；共享数据到期须自动回收。导出文件默认加密并设置 7 天有效期。

第 5 章 日志与审计

5.1 审计日志

账号登录、权限变更、数据导出、跨租户访问尝试均须记录审计日志，日志保留 180 天，且不可被业务账号删除。

5.2 事件响应

发现串租户访问线索后，须在 1 小时内冻结相关账号并启动调查，24 小时内向租户管理员通报，7 个工作日内出具结论与整改方案。

第 6 章 违规处理

6.1 责任认定

因代码缺失租户过滤导致数据泄露的，追究开发与评审责任；因运维操作扩大权限的，追究运维与管理责任。

6.2 处罚

视情节给予通报批评、绩效扣减、权限回收直至解除劳动合同；造成客户损失或监管处罚的，依法追偿。